

MULTI-AGENT APPLICATION SECURITY AUDIT REPORT

Ann Real Estate — Portal & Private CRM

Ultra-Luxury Dubai Property Portal, Advisory Pipeline & API Engine Assessment

ASSESSMENT DATE

September 30, 2026

AUDIT SCOPE

Full Stack (Code + Live API)

TARGET ARCHITECTURE

Node.js / PostgreSQL / SPA

ASSESSMENT TEAM

Specialist Agents 1-6

OVERALL SECURITY SCORE

38 / 100

HIGH RISK (Grade: F) — Critical authentication bypass and cleartext credential disclosure detected.

TOTAL FINDINGS

13

2 Critical, 3 High, 3 Medium, 3 Low, 2 Informational issues verified.

PRIVACY COMPLIANCE

FAIL

Non-compliant with UAE Federal Decree-Law No. 45 on Personal Data Protection.

UX & DESIGN GRADE

A- (92%)

High aesthetic finish, responsive layouts, accurate financial formulas.

Security & Quality Scorecard Breakdown

Audit Category	Score	Status	Primary Assessment Observations
Authentication & Session Management	15 / 100	CRITICAL RISK	Cleartext admin/agent passwords exposed in public client JS; authentication bypass on admin routes.
Authorization & Access Control	20 / 100	CRITICAL RISK	Fail-open access on CRM endpoints; unauthenticated callers can dump all client leads and records.
Input Validation & Output Encoding	45 / 100	HIGH RISK	Stored XSS in CRM notifications/cards; CSV formula injection in lead spreadsheet export.
Architecture & Data Safety	68 / 100	MODERATE	Parameterized SQL queries throughout; lacks database transactions during multi-table deal closing.
UI, UX & Accessibility (WCAG 2.2 AA)	72 / 100	GOOD	Luxury aesthetic and smooth mortgage math; missing input label bindings and multiple h1 headers.
Performance & Operational Reliability	78 / 100	GOOD	Sub-second Node.js response times; image assets exceed 2.5 MB without WebP/AVIF compression.

Risk & Findings Summary Matrix

ID	Vulnerability / Finding Description	Category	Severity	CVSS	Remediation Priority
SEC-01	Plaintext Admin & Staff Passwords Exposed in Public Client JS	Data Exposure	CRITICAL	9.8	Immediate (P0)

ID	Vulnerability / Finding Description	Category	Severity	CVSS	Remediation Priority
SEC-02	Complete Broken Access Control & Fail-Open Administrative Endpoints	Access Control	CRITICAL	9.1	Immediate (P0)
SEC-03	Stored XSS via Unescaped Ingestion in CRM Dashboards & Notifications	Injection	HIGH	8.0	Immediate (P0)
SEC-04	Overly Permissive CORS Header (Access-Control-Allow-Origin: *)	Configuration	HIGH	7.5	Short Term (P1)
SEC-05	Missing Rate Limiting and Lockout on Authentication API	Authentication	HIGH	7.3	Short Term (P1)
SEC-06	Plaintext Password Storage in PostgreSQL Database Without Hashing	Cryptography	MEDIUM	6.5	Short Term (P1)
SEC-07	CSV / Formula Injection in Lead Dossier Spreadsheet Export	Input Handling	MEDIUM	5.8	Medium Term (P2)
SEC-08	Lack of Transaction Safety (BEGIN/COMMIT) During Deal Closing	Data Integrity	MEDIUM	5.3	Medium Term (P2)
A11Y-01	Missing Explicit for/id Bindings on Form Controls (WCAG 1.3.1)	Accessibility	LOW	—	Medium Term (P2)
A11Y-02	Seven Top-Level <h1> Tags Breaking Document Outline	Accessibility	LOW	—	Medium Term (P2)
FUNC-01	Confirmation Message Mentions "Jay Real Estate" Instead of "Ann"	Functional QA	LOW	—	Immediate (P0)
PERF-01	Uncompressed Hero Image Payloads (>2.5 MB) Lacking WebP/AVIF	Performance	INFO	—	Long Term (P3)
SEC-09	Missing Standard HTTP Security Headers (CSP, HSTS, X-Frame-Options)	Configuration	INFO	—	Short Term (P1)

Detailed Findings & Remediation Dossiers

SEC-01

Plaintext Admin & Staff Passwords Exposed in Public Client JS

CRITICAL

CVSS: 9.8

AFFECTED FILE: js/seedData.js (Lines 401–435) | Loaded publicly by index.html:2009

CWE / OWASP: CWE-798 (Use of Hard-coded Credentials) / OWASP A02:2021 (Cryptographic Failures)

EMPIRICAL REPRODUCTION EVIDENCE:

```
curl.exe -s http://localhost:3000/js/seedData.js | Select-String 'admin123'
==> Output: password: "admin123", (Master Administrator account completely exposed)
```

TECHNICAL & BUSINESS IMPACT: Any web visitor inspecting DevTools or scraping static scripts immediately acquires master administrative and broker credentials. An attacker can hijack the CRM, view confidential client negotiations, and alter property listings.

Recommended Remediation: Purge staffLogins completely from js/seedData.js. Authenticate exclusively via server-side endpoints verifying hashed credentials.

SEC-02

Complete Broken Access Control & Fail-Open Administrative Endpoints

CRITICAL

CVSS: 9.1

AFFECTED FILE: server.js (Lines 265–385) & db/database.js (Lines 440–475)

CWE / OWASP: CWE-306 (Missing Authentication) / CWE-285 (Improper Authorization) / OWASP A01:2021

EMPIRICAL REPRODUCTION EVIDENCE:

```
# Unauthenticated request without ANY headers:
curl.exe -s http://localhost:3000/api/admin/leads
==> Output: {"success":true,"count":40,"leads":[{"full_name":"Lord Alistair Sterling","budget_aed":5000000
0,...}]}
```

TECHNICAL & BUSINESS IMPACT: Fail-open authorization logic checks user && user.role === 'agent'. When no headers are sent, user is null, causing the backend to omit the agent restriction and dump all 40 client records, phone numbers, and budgets to anyone on the internet.

Recommended Remediation: Enforce mandatory token verification middleware on all /api/admin/* routes. Deny requests by default with 401 Unauthorized if a cryptographically valid token is absent.

SEC-03

Stored Cross-Site Scripting (XSS) in CRM Notifications & Kanban

HIGH

CVSS: 8.0

AFFECTED FILE: js/app.js (Lines 1574, 1798, 1947)

CWE / OWASP: CWE-79 (Improper Neutralization of Input) / OWASP A03:2021 (Injection)

VULNERABLE IMPLEMENTATION:

```
list.innerHTML = data.recent.map(item => `
  <div class="notif-name">` + item.full_name + `</div>
`).join('');
```

TECHNICAL & BUSINESS IMPACT: Public visitors submitting a script payload via POST /api/leads execute malicious JavaScript in the browser session of an administrator opening the CRM notification bell or Kanban board.

Recommended Remediation: Implement an HTML entity encoder (escapeHTML()) or assign user-controlled values strictly via.textContent / innerText.

SEC-04 & SEC-05 Wildcard CORS Headers & Lack of Login Rate Limiting**HIGH****CVSS: 7.5 / 7.3****OBSERVATIONS:**

1. **CORS Misconfiguration:** `server.js:91` issues `Access-Control-Allow-Origin: *` on all endpoints, allowing third-party sites to perform cross-origin data extraction against authenticated users.
2. **Brute-Force Login Exposure:** `POST /api/auth/login` lacks rate limiting or account lockout, allowing automated credential stuffing attacks.

Recommended Remediation: Whitelist approved origins in CORS headers; enforce an IP sliding-window limiter on `/api/auth/login` (maximum 5 attempts per 5-minute window).

Functional QA Execution Results

Test ID	User Flow / Feature Tested	Expected Result	Actual Result	Status
FT-01	Property Catalog Filtering	Filters properties by community & price	Filtered results match criteria	PASS
FT-02	Mortgage & Fee Calculator	Computes DLD fee (4% + AED 580) & loan	Formulas match Dubai statutory rules	PASS
FT-03	Public Lead Ingestion	Captures lead, returns VIP tracking code	Lead recorded, 201 Created returned	PASS
FT-04	Anti-Bot Honeypot Field	Silently absorbs bot form submissions	Returns 200 with code ANN-BOT-VOID	PASS
FT-05	Lead Confirmation Copy	Brand name says "Ann Real Estate"	Message says "Jay Real Estate"	FAIL
FT-06	CRM Authentication Check	Rejects invalid credentials with 401	Returns 401 Invalid email/password	PASS
FT-07	CRM Admin Leads Access Control	Rejects unauthenticated callers	Dumps all 40 leads (Fail-open)	FAIL
FT-08	Deal Won Statutory Commission	Calculates 2% statutory brokerage fee	Commission accurately computed	PASS
FT-09	Client Lead Excel/CSV Export	Downloads formatted spreadsheet CSV	CSV created with 13 data columns	PASS
FT-10	Stale Inactivity Lead Alert	Flags inquiries uncontacted for >3 days	Correctly identifies inactive leads	PASS

Strategic Remediation Roadmap

Phase	Action Items	Target Vulnerabilities	Impact	Effort
Phase 1: Immediate (Next 24 Hours)	1. Purge staffLogins and lead records from js/seedData.js. 2. Enforce authentication on all /api/admin/* routes; reject missing tokens. 3. Fix confirmation brand copy in server.js:258.	SEC-01, SEC-02, FUNC-01	CRITICAL	Small
Phase 2: Short Term (Next 7 Days)	1. Neutralize Stored XSS via HTML encoding in js/app.js. 2. Migrate database passwords to bcrypt (cost factor 12). 3. Implement login rate limiting on /api/auth/login. 4. Restrict CORS origins and configure CSP/HSTS/X-Frame headers.	SEC-03, SEC-04, SEC-05, SEC-06, SEC-09	HIGH	Medium

Phase	Action Items	Target Vulnerabilities	Impact	Effort
Phase 3: Medium Term (Next 30 Days)	1. Wrap deal closing operations in DB transactions (BEGIN/COMMIT). 2. Neutralize CSV formula characters (=, +, -, @). 3. Provide explicit for/id attributes on all form inputs.	SEC-07, SEC-08, A11Y-01, A11Y-02	MEDIUM	Small
Phase 4: Long Term (Continuous)	1. Convert hero images to WebP/AVIF with responsive srcset. 2. Establish automated CI security regression test suite.	PERF-01, Quality	LOW	Medium

Positive Engineering Controls Observed

✓ **SQL Injection Prevention:** Parameterized queries (\$1, \$2) used uniformly across all database operations in db/database.js.

✓ **Environment Secret Protection:** server.js enforces strict blocking of HTTP requests targeting .env files, returning 403 Forbidden.

✓ **Path Traversal Defense:** Static routing utilizes path.normalize and directory prefix validation to prevent directory traversal.

✓ **Anti-Spam Architecture:** Zero-friction honeypot (website_hp) absorbs automated spam submissions without requiring intrusive CAPTCHAs.

✓ **SEO & Discoverability:** Complete Schema.org RealEstateAgent JSON-LD, OpenGraph cards, Twitter cards, and robots.txt crawl directives.